



ANALYSIS REPORT

10398871.r1.v2 NUMBER

Malware Analysis Report

2022-10-13 DATE

Notification

- Author : github.com/miho030
- TLP Classification : TLP:CLEAR
- Purpose : Personal development and public information sharing (non-commercial)

This report is the result of independent research and self-development by an individual malware analyst. It is shared for the benefit of the cybersecurity community and the public good. This document is provided "as-is" information purpose only. All content reflects the author's technical opinion at the time of analysis and **does not represent the official position of any specific organization, institution, or government agency**. No warranties of any kind are expressed or implied regarding the contents of this report. Please note that some of the information in this document (eg., malware hashes, C2 addressed) may be security-sensitive. Caution is advised when testing or applying this data to live systems. All responsibility for the use of this material rests solely with the user.

You are free to use this report for the following purposes, as long as the information is not misused and proper attribution is provided:

- Educational or research purpose
- Threat intelligence sharing
- Reference material for malware response and defense

The format of this report is based on and adapted from the (public domain docs) TLP:WHITE malware analysis reports published by *America's Cyber Defense Agency (CISA)*. I hereby clearly state that this report is not affiliated with CISA, *Department of Homeland Security (DHS)*, or any government entity. The non-commercial reuse of this format is permitted under the following legal and policy bases:

- [CISA - Traffic Light Protocol \(TLP\)](#)
"Subject to standard copyright rules, TLP:WHITE information may be distributed without restriction."
- [U.S Copyright Office - 17 U.S.C. § 105](#)
"Copyright protection under this title is not available for any work of the United States Government."
- [FIRST.org - TLP](#)
"TLP:CLEAR information may be shared without restriction"

However, if you create derivative works based on this report, you must include this 'Notification' section with proper attribution to the original author and source.

Summary

Description

CISA received a benign 32-bit Windows executable file, a malicious dynamic-link library (DLL) and an encrypted file for analysis from an organization where cyber actors exploited vulnerabilities against Zimbra Collaboration Suite (ZCS). Four CVEs are currently being leveraged against ZCS: CVE-2022-24682, CVE-2022-27924, CVE-2022-27925 chained with CVE-2022-37042, and CVE-2022-30333. The executable file is designed to side-load the malicious DLL file. The DLL is designed to load and Exclusive OR (XOR) decrypt the encrypted file. The decrypted file contains a Cobalt Strike Beacon binary. The Cobalt Strike Beacon is a malicious implant on a compromised system that calls back to the command and control (C2) server and checks for additional commands to execute on the compromised system.

For more information on cyber actors exploiting vulnerabilities in ZCS, see joint CSA: Threat Actors Exploiting Multiple CVEs Against Zimbra Collaboration Suite.

Submitted Files (1)

7462acb6f1a957758ed211d71a57125e08d6b02d66e790f4164c4f69ab25c5b8 (Mario.jpg)

Additional Files (1)

302e1152c2710ad56ef1ff5536bb6539f6ac6901caba28954c2b160f9c7ac518 (Server.exe)

IPs (1)

188.242.138.137

Findings

7462acb6f1a957758ed211d71a57125e08d6b02d66e790f4164c4f69ab25c5b8

Tags

njrat

Trojan

jpeg

Details

File name	Mario.jpg
File size	138.01 KB (141326 bytes)
File type	JPEG, multimedia, image, jpeg, jpg
Magic	JPEG image data, JFIF standard 1.01, aspect ratio, density 1x1, segment length 16, baseline, precision 8, 604x604, frames 3
MD5	a98e0ab4be7da0080d559f75385b0a46
SHA256	7462acb6f1a957758ed211d71a57125e08d6b02d66e790f4164c4f69ab25c5b8
ssdeep	3072:xbvS9Sp07hiT56gE+ptaSadfq9gck4nAXULDNmx/V3Zr:xe21TMgELSKfZBk4AkLDNmxv
Entropy	23

Antivirus

Ahnlab	Undetected
Alyac	Undetected
Avast	Win32:KeyloggerX-gen [Trj]
Avira	TR/Dropper.Gen
Bitdefender	Generic.MSIL.Bladabindi.F1687BCF
CrowdStrike Falcon	Unable to process file type
Fortinet	MSIL/Bladabindi.AS!tr
Kaspersky	HEUR:Trojan.Win32.Generic
MacAfee	Undetected
symantec	Undetected

YARA Rules

No matches found.

ssdeep Matches

No matches found.

Packers/Compilers/Cryptos

No Packer found.

Relationships

302e1152c27..	Created	302e1152c2710ad56ef1ff5536bb6539f6ac6901caba28954c2b160f9c7ac518
---------------	---------	--

Additional Malware Analysis Reports are HERE!

[7462acb6f1a957758ed211d71a57125e08d6b02d66e790f4164c4f69ab25c5b8.exe Malware Analysis Reports](#)

Description



Figure 1 - Target malware file preview and founded hidden data

The file to be analyzed shows the character of DS's 'S' game. The resolution of the file to be analyzed is 604x604, and the resolution is very low at 96 DPI. As a result of the analysis based on the file capacity of 140KB, which is a rather large value compared to the low-quality image, it was confirmed that 35080 Byte additional data existed after the EoF of the file.

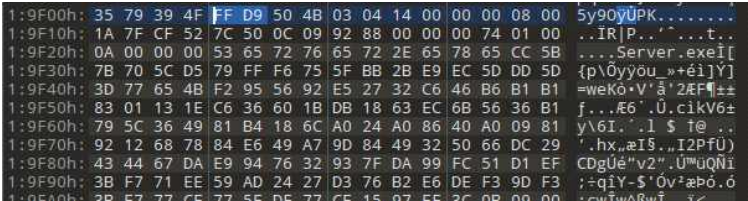


Figure 2 - Additional file data inserted from the end of the jpeg image

As a result of checking the end point of the file through 010Editor, a suspicious text was found at the bottom of the file.

Value
PK IR P t Server.exe PK 8

Since it was confirmed that the executable file for the Windows system was included after the end of the image file to be analyzed, the image file was temporarily changed to a compressed file extension to extract a suspicious file, 'Server.exe' that was additionally attached to the file to be analyzed.



Figure 3 - Hidden file extracted from archived image file

Windows executable, which is included in the malicious image file to be analyzed, is a BotNet client program named nJRAT (Bladabindi/NjwOrm). It has the most educational information and guides among the BotNet tools distributed in the market, and is one of the easily available RAT attack tools. It is famous for being a favorite attack tool for attackers to find lecture materials on YouTube.

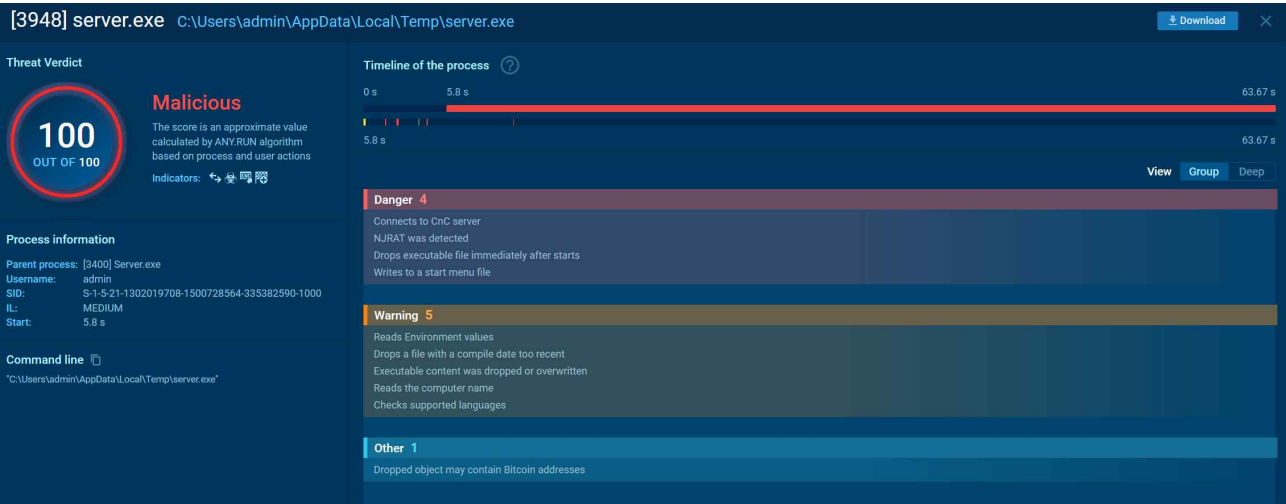


Figure 4 - Dynamic Analysis Results for Server.exe Files (Any.Run)

The analysis report analyzing the corresponding 'Server.exe' file can be found in the link below.

7462acb6f1a957758ed211d71a57125e08d6b02d66e790f4164c4f69ab25c5b8.exe Malware Analysis Reports

Recommendations

Author recommends that users and administrators consider using the following best practices to strengthen the security posture of their organization's systems. Any configuration changes should be reviewed by system owners and administrators prior to implementation to avoid unwanted impacts. The following checklist reflects the author's personal best-practice recommendations for safeguarding endpoints and servers. Review and test any configuration change in a lab or staging environment before applying it to production systems.

- Maintain up-to-date antivirus signatures and engines.
- Keep operating system patches up-to-date.
- Disable File and Printer sharing services. If these services are required, use strong passwords or Active Directory authentication.
- Restrict users' ability (permissions) to install and run unwanted software applications. Do not add users to the local administrators group unless required.
- Enforce a strong password policy and implement regular password changes.

- Exercise caution when opening e-mail attachments even if the attachment is expected and the sender appears to be known.
- Enable a personal firewall on agency workstations, configured to deny unsolicited connection requests.
- Disable unnecessary services on agency workstations and servers.
- Scan for and remove suspicious e-mail attachments; ensure the scanned attachment is its "true file type" (i.e., the extension matches the file header).
- Monitor users' web browsing habits; restrict access to sites with unfavorable content.
- Exercise caution when using removable media (e.g., USB thumb drives, external drives, CDs, etc.).
- Scan all software downloaded from the Internet prior to executing.
- Maintain situational awareness of the latest threats and implement appropriate Access Control Lists (ACLs).

Additional information on malware incident prevention and handling can be found in National Institute of Standards and Technology(NIST) Special Publication 800-83, "**Guide to Malware Incident Prevention & Handling for Desktops and Laptops**".

Contact Information

- Github (github.com/miho030)

Document FAQ

Q. Is it safe to deploy the IOCs from this report directly in a live environment?

A. Best practice is to apply the IOCs in a test or staging environment first, verify there are no false positives, and then roll them out to production in phases.

Q. May I redistribute this report for commercial purposes?

A. This report may be freely shared for non-commercial and public-interest use only. Creating commercial derivative works requires explicit permission from the author.

Q. Where can I obtain malware samples for my own analysis?

A. You can legally download samples from public repositories and sandboxes such as VirusTotal, MalwareBazaar, and ANY.RUN. If you execute them locally, always use an isolated analysis environment (e.g., a virtual machine or Cuckoo sandbox).